

Marco del Sistema de Gestión de Información

Contexto organizacional

La empresa mexicana NovaTech Solutions es una organización dedicada al desarrollo de software y servicios digitales para pequeñas y medianas empresas; gestionando datos personales de clientes, información financiera, sistemas web, propiedad intelectual e infraestructura tecnológica crítica.

Contexto interno y externo

Contexto interno: El contexto interno de la organización se compone de las áreas de desarrollo de software, atención a clientes y administración. La operación de estas áreas depende de una infraestructura tecnológica basada en servidores en la nube, aplicaciones web, bases de datos, correo corporativo y almacenamiento en la nube.

Estos servicios manejan información sensible como datos personales de clientes y empleados, credenciales de acceso, información financiera, propiedad intelectual y documentos contractuales.

Contexto externo: El contexto externo de la organización se compone de autoridades regulatorias, proveedores de servicios tecnológicos y competidores dentro del sector de desarrollo de software y servicios digitales.

Asimismo, la organización se ve influenciada por incidentes de seguridad ocurridos dentro de la misma, tales como filtraciones de datos, accesos no autorizados y fallos que afecten a la continuidad del negocio, la necesidad de cumplir con la legislación vigente de protección de datos en México y su reputación basada en la confianza de sus clientes.

Partes interesadas

Las principales partes interesadas de la organización incluyen:

- Clientes
- Empleados
- Proveedores de servicios tecnológicos
- Autoridades regulatorias
- Socios comerciales

Necesidades y expectativas

Las partes interesadas esperan que la organización:

- Proteja la confidencialidad, integridad y disponibilidad de la información.
- Garantice la continuidad de los servicios ofrecidos.
- Cumpla con la legislación aplicable de protección de datos.
- Mantenga la seguridad de sus sistemas e infraestructura.

Alcance del sistema de gestión de seguridad de la información

La organización NovaTech Solutions, sensibilizada con la importancia de la seguridad de la información como mecanismo para cumplir con sus objetivos de negocio, y garantizando la confidencialidad, integridad y accesibilidad de los activos de información, define como alcance de su sistema de seguridad de la información el siguiente:

Los sistemas de información que dan soporte al proceso de negocio de:

- Desarrollo y mantenimiento de plataformas web, así como de gestionar los repositorios de código.
- Soporte técnico y gestión de solicitudes.
- Facturación, actividades contractuales y pagos financieros.

Asimismo, el alcance incluye la infraestructura tecnológica utilizada por la organización como:

- Servidores en la nube.
- Aplicaciones web.
- Bases de datos de clientes y empleados.
- Correo corporativo.
- Almacenamiento en la nube.

El SGSI es aplicable al personal interno, proveedores de servicios tecnológicos y terceros que tengan acceso a la información de la organización.

Quedan fuera del alcance aquellos sistemas o servicios que no estén directamente relacionados con los procesos antes mencionados.

Objetivos en materia de seguridad de la información

NovaTech Solutions reconoce la importancia de proteger la confidencialidad, integridad y disponibilidad de la información con la cual trabaja para mantener la confianza de sus clientes y empleados.

Es por este motivo por el cual la organización tiene como objetivo salvaguardar los activos de información de posibles filtraciones, modificaciones no autorizadas, pérdida parcial o total de ésta, así como de posibles amenazas que sean descubiertas en el futuro.

En complemento a lo anterior, se establecen los siguientes objetivos específicos de seguridad de la información:

- Asegurar que el personal reciba capacitación en seguridad de la información de manera anual.
- Garantizar que los sistemas críticos cuenten con mecanismos de control de acceso y autenticación segura implementados.
- Reducir a cero incidentes críticos de fuga de información relacionados con datos sensibles de empleados y clientes en periodos anuales.
- Garantizar la integridad de la información manejada por la organización, asegurando que el 100% de los datos críticos cuenten con mecanismos de control de cambios y validación.
- Mantener la disponibilidad de los sistemas críticos de información durante la operación del negocio.
- Salvaguardar la confidencialidad de la propiedad intelectual de la empresa, asegurando que el código fuente esté protegido mediante controles de acceso y almacenamiento seguro.
- Asegurar que los procesos críticos del negocio cuenten con planes de continuidad y recuperación documentados, actualizados y probados al menos una vez al año.
- Garantizar que los incidentes de seguridad sean documentados, clasificados y analizados conforme a los procedimientos establecidos.

Roles y responsabilidades

Para la correcta implementación, operación y mejora continua del sistema de gestión de seguridad de la información, NovaTech Solutions define los siguientes roles y responsabilidades dentro de la organización:

Dirección general

- Definir los objetivos de seguridad de la información.
- Asignar los recursos necesarios para el correcto funcionamiento del SGSI.
- Aprobar la implementación del SGSI.
- Promover una cultura de seguridad dentro de la organización.

Comité de seguridad de la información

- Diseñar, implementar y mantener el SGSI.
- Supervisar el cumplimiento de políticas y controles de seguridad.
- Gestionar incidentes de seguridad de la información.
- Reportar el desempeño del SGSI a la dirección.
- Realizar análisis de riesgos de manera periódica, por lo menos una vez al año.

Área de administración

- Mantener la confidencialidad de la información financiera y contractual.
- Gestionar adecuadamente los documentos legales.
- Controlar el acceso a información administrativa sensible.

Área de desarrollo de software

- Aplicar buenas prácticas de desarrollo seguro para proteger las soluciones tecnológicas de vulnerabilidades y ataques cibernéticos.
- Documentar las actualizaciones y parches aplicados a los programas.
- Proteger la integridad del código fuente.
- Restringir la modificación de la rama principal (main) del repositorio únicamente a usuarios autorizados, mediante procesos de aprobación previa.

Área de atención a clientes

- Proteger la información sensible manejada durante sus actividades.
- No divulgar información confidencial.

- Utilizar únicamente medios oficiales para la gestión de información.

Empleados

- Cumplir con las políticas de seguridad de la información.
- Proteger sus credenciales de acceso.
- Renovar sus contraseñas cada 3 meses en sistemas críticos, y cada 6 meses en otros sistemas.
- Reportar incidentes o actividades sospechosas.
- Participar en capacitaciones de seguridad otorgadas por la empresa.

Relación con ISO 27001

El sistema de gestión de seguridad de la información (SGSI) de NovaTech Solutions ha sido diseñado y estructurado con base en los lineamientos establecidos en la norma internacional ISO/IEC 27001, la cual permite gestionar riesgos, establecer controles e integrar la seguridad en la operación diaria de la organización.

El SGSI se encuentra alineado con los requisitos de la norma con respecto a:

- Definir el contexto de la organización, considerando factores internos y externos, así como la identificación de partes interesadas y la delimitación del alcance del SGSI.
- Identificar, analizar y evaluar los riesgos que puedan afectar a los activos de información y a los objetivos de la organización.
- Seleccionar, implementar y mantener controles de seguridad coherentes con el tratamiento de riesgos realizado.
- Establecer objetivos de seguridad de la información que sean medibles, verificables y alineados con los resultados del análisis de riesgos.
- Implementar procesos de gestión de incidentes que incluyan la detección, reporte, análisis, contención y recuperación ante incidentes de seguridad.
- Desarrollar programas de capacitación y concientización en seguridad de la información para el personal y partes involucradas.
- Definir y monitorear indicadores de desempeño para evaluar la eficacia del SGSI.
- Implementar acciones de mejora continua mediante la gestión de no conformidades, auditorías internas y revisión de resultados.
- Establecer planes de continuidad del negocio y recuperación ante desastres para asegurar la disponibilidad de los servicios críticos.

Relación con la legislación aplicable

La organización NovaTech Solutions opera en cumplimiento de la legislación aplicable en materia de tratamiento de datos existentes en el país de México. Es por esto que NovaTech Solutions gestiona los datos de clientes, empleados y terceros conforme a la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP). Asimismo, NovaTech Solutions opera con concordancia bajo los derechos ARCO, permitiendo que los titulares de datos personales puedan:

- Acceder a los datos personales que posee la organización, conocer las acciones a realizar con ellos y bajo qué condiciones.
- Rectificar datos inexactos que tenga la organización.
- Solicitar la eliminación de datos personales.
- Oponerse a la utilización de sus datos para ciertos fines.

Modelo de gestión de riesgos

El sistema de gestión de seguridad de la información de NovaTech Solutions se basa en la metodología OCTAVE Allegro, la cual permite identificar, analizar y evaluar los riesgos existentes en la organización que afecten a los objetivos en materia de seguridad de la información. La metodología OCTAVE Allegro establece el siguiente proceso para la gestión de riesgos:

1. Establecer criterios de medición del riesgo, definir áreas de impacto en la organización y asignar valores de prioridad para cada uno.
2. Desarrollar un perfil de activos de información y documentar la información ligada a los activos de información críticos.
3. Identificar contenedores de activos de información a los cuales también se deberán aplicar medidas de seguridad.
4. Identificar áreas de preocupación de la organización que puedan afectar a los activos de información previamente establecidos.
5. Identificar escenarios de amenaza, las cuales se definen como situaciones en las que el activo se puede ver comprometido.
6. Identificar riesgos, documentar las consecuencias relacionadas con cada escenario de amenaza identificado en el paso previo.
7. Analizar los riesgos utilizando los criterios de medición del primer paso para definir un valor por cada área de impacto. Asimismo, se calcula su puntaje de riesgo según los objetivos de la organización.
8. Seleccionar un enfoque de mitigación de riesgo, el cual puede variar entre: mitigar, aceptar, transferir o evitar el riesgo. Una vez hecho esto se calcula el riesgo residual después de implementar el control seleccionado.

Finalmente, los riesgos identificados son monitoreados y revisados de manera periódica, por lo menos 2 veces al año, con el fin de asegurar su adecuada gestión y adaptación ante cambios en el entorno, nuevas amenazas o modificaciones en los procesos de la organización.

Ciclo de mejora continua

El sistema de gestión de seguridad de información de NovaTech Solutions se basa en la metodología de mejora continua PDCA (Plan-Do-Check-Act), la cual permite gestionar, evaluar y mejorar continuamente la seguridad de la información dentro de la organización.

Las acciones por realizar en cada fase del modelo son las siguientes:

- **Plan (Planear):** En esta etapa se definen los objetivos de seguridad de la información, el alcance del SGSI y se realiza la identificación, análisis y evaluación de riesgos que puedan afectar a los activos de información. Asimismo, se establecen políticas, procedimientos y controles necesarios para mitigar los riesgos identificados.
- **Do (Hacer):** En esta fase se implementan los controles de seguridad, políticas y procedimientos definidos en la etapa anterior. Esto incluye la ejecución de controles técnicos y administrativos, la gestión de accesos, la capacitación del personal y la operación diaria del SGSI.
- **Check (Verificar):** En esta etapa se monitorea y evalúa el desempeño de los controles implementados mediante auditorías internas, revisiones de indicadores de seguridad y análisis de incidentes.
- **Act (Actuar):** Con base en los resultados obtenidos, se implementan acciones correctivas y de mejora continua para fortalecer el SGSI. Estas acciones pueden derivarse de auditorías, incidentes de seguridad, cambios en los riesgos o en el contexto organizacional.